

软件过程管理-课后作业/Assgt_01

吴宜蔓 2022141490342

一 项目边界与假设

本文先定义一个**基线项目**，以确保后续过程清单不是空泛讨论，而是可以直接套用到课程作业与团队实践中的对象。

基线项目定义为：“**企业知识问答与工单协同助手**”。

基线项目描述：用户通过 Web 与微信小程序提交问题或工单，系统根据企业知识库、业务规则与第三方大模型 API 生成答案、摘要、建议分类和草拟回复；后端保存会话、调用日志、成本数据、人工审核结果与业务指标。

基线项目备注：项目项目不训练自有基础模型，不开发硬件，不做本地推理；重点在于应用层编排、检索增强、权限控制、日志审计与持续交付。

推荐基线团队规模为 **8-9 人**。角色分配可按以下方式组织：

- 1 名 PM/PO（兼业务分析）
- 1 名技术负责人/架构师
- 2 名后端工程师
- 1 名 Web 前端工程师
- 1 名小程序工程师

- 1 名 AI 应用工程师
- 1 名 QA/自动化测试工程师
- 1 名 DevOps/SRE（在 8 人团队中可与后端/技术负责人兼职）

若只有 6-7 人，则 QA、DevOps、安全与合规职责需要由技术负责人和后端兼职；

若接近 10 人，则优先把 QA 自动化与 DevOps/SRE 拆成独立角色，并补充 1 名安全/合规或数据治理负责人。

本文给出两种假设场景。

维度	场景 A	场景 B
业务形态	企业内部工具或普通互联网增值功能	面向外部客户/公众，或面向政企客户
团队规模	8 人	9-10 人
开发模式	敏捷为主：双周迭代，需求连续澄清，持续集成，周级发布	混合模式：前期需求/架构/合规里程碑 + 双周迭代开发，月度或双月发布
交付节奏	Sprint 内持续合并，功能开关上线	阶段门更明确，需上线审批、灰度与回归加严
合规假设	不处理高敏感个人信息，不给模型高风险自治权限	处理个人信息/商密，或具有生成式 AI 外部服务属性，需要审计留痕与更强审批

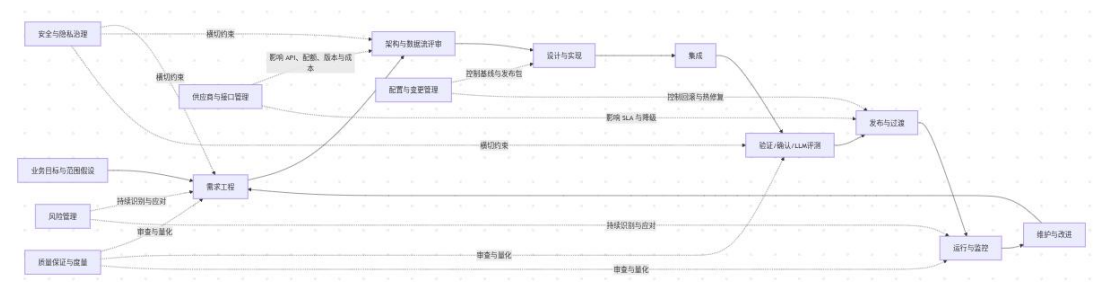
过程能力目标	核心过程以 CL2 为主	核心关键过程以 CL3 为主， 其他过程至少 CL2
文档深度	最小充分文档集	增加 DPIA/数据流图/供应商审查/审计留痕
更适合的场景	需求不确定、试错快、产品导向	合同导向、客户验收重、合规和可追溯性要求高

二 过程清单

12207:2017 的目录显示，标准把过程分成

- 协议过程
- 组织使能过程
- 技术管理过程
- 技术过程四大域，

对本项目而言，最有价值的做法不是逐个照搬全部组织级过程，而是在项目层面定义一套“足够完整、但不臃肿”的过程集。



下表是**面向本项目的软件过程定义**。它以 12207 的过程精神为骨架，以小团队可执行性为边界，以 LLM API 集成的真实风险为增强点。

过程	目标	主要活动	输入	输出/关键产物
供应商与接口管理	管住大模型 API、云、短信/登录等第三方依赖的合同、版本、数据边界、配额与成本	供应商选型、接口抽象、版本固定、配额告警、SLA/退役跟踪、降级预案	业务需求、预算、数据分类、供应商条款	供应商清单、接口契约、版本矩阵、降级方案、成本看板
项目策划与控制	让需求、资源、里程碑、范围与风险始终可见、可调	计划编制、迭代排期、WIP 控制、燃尽/燃起、里程碑复盘	范围说明、人员可用性、优先级、风险清单	项目章程、路线图、Sprint 计划、周报/里程碑评审记录
需求工程	将业务目标转成可开发、可测试、可验收的需求集合	场景梳理、NFR 定义、验收标准、数据与权限约束、提示词/检索需求分解	业务目标、法规约束、用户反馈、历史工单	backlog、用户故事、验收标准、NFR 清单、数据分类标签
架构定义	在性能、可靠性、隐私、成本和可演进性之间做系统级权衡	架构选型、数据流图、权限边界、缓存/队列/检索方案、ADR 评审	需求/NFR、已有系统、供应商约束	架构图、ADR、数据流图、接口边界说明
设计与实现	以可读、可测、可维护方式完成功能交付	详细设计、编码、单元测试、代码评审、提示模板与工具调用实现	已确认需求、架构与 ADR	源码、测试代码、PR 记录、模块设计说明、提示模板版本
集成	把前端、后端、检索、模型调用与第三方服务可靠组合起来	联调、契约测试、环境配置、冒烟测试、依赖版本对齐	各模块构建物、接口规范、环境变量	集成包、环境清单、联调记录、冒烟报告
验证与确认	证明“做对了”和“做的是对的”	单元/集成/回归/E2E、UAT、离线评测集、红队提示、人工抽检	需求与验收标准、测试策略、样本集	测试用例、测试报告、评测集、评测分数、UAT 结论
发布与过渡	安全、可回滚地把增量变更交到生产环境	发布审批、灰度/金丝雀、特性开关、数据	已通过测试的构建物、发布	发布单、变更记录、回滚预案、上

		库迁移、回滚演练、用户培训	单	线核对表、版本说明
运行与维护	在真实流量下维持服务可用、可观察、可持续优化	监控、告警、值班、事故响应、缺陷修复、知识库更新、容量伸缩	运行日志、告警、用户反馈、工单	运行手册、事故单、复盘报告、修复版本、SLO 看板
配置与变更管理	管住代码、模型参数、提示模板、基础设施与发布基线	仓库策略、基线识别、版本标记、CR 流程、回溯链路维护	源码、配置、提示模板、镜像、IaC	配置基线、变更记录、版本标签、制品清单
质量保证与度量	让过程与产物持续满足定义的质量门槛	质量计划、过程检查、审查点、指标采集、偏差纠正、复盘改进	项目计划、质量目标、流程定义	质量计划、度量仪表盘、审查记录、改进行动项
风险管理	识别并控制项目、技术、供应商、合规与成本风险	风险识别、评估、响应、监控、升级、应急预案	计划、架构、供应商条款、法规要求	风险登记册、热力图、应对计划、应急清单
安全与隐私治理	将数据最小化、访问控制、日志约束、模型安全要求嵌入全流程	数据分类、DPIA/PIA、最小权限、密钥管理、日志脱敏、红队与内容安全	法规要求、数据流、功能设计、供应商条款	数据流图、权限矩阵、脱敏规则、DPIA/PIA、密钥/密文策略
信息与知识管理	让需求、决策、运行经验与提示资产可检索、可复用、可交接	文档最小集维护、ADR 归档、提示模板版本化、事故知识沉淀	各过程输出、评测与运维记录	文档目录、ADR 库、操作手册、复盘库、FAQ/知识库

三 标准映射与剪裁

相关文件描述

1. 从标准关系看，12207 负责回答“**项目应该有哪些生命周期过程**”
2. 15504/330xx 负责回答“**这些过程做到什么程度才算有能力**”

3. 15504-2 明确过程评估使用**过程维度 + 能力维度**的二维模型；
4. 15504-5 是基于 12207:2008 的软件生命周期 PAM；
5. 33001 提供过程评估概念和术语；
6. 33002 规定如何做一个客观、一致、可重复、具代表性的评估；
7. 33004 定义 PRM/PAM/成熟度模型的关系；
8. 33020 定义能力测量框架；3
9. 3022 则把 12207 过程与 33020 的能力属性结果关联起来，用于证明 **1-3 级**。

因此，下表采用“**最近似过程**”映射：它不是为了做正式认证用逐条法律式比对。

下表中的 12207 条款号来自 12207:2017 样页目录；15504/SPICE 过程编号来自 15504-5 样页目录

与过程条目；能力层级与属性来自 33020 样页和 33022/33001/33002/33004 的官方概要。

本项目过程	12207:2017 / GB/T 8566-2022 对 应	15504 / 33061 最 近似过程	33001 家族 下的评估落点	场景 A	场景 B
供应商与接口管理	6.1.1 获取； 6.1.2 供方	AGR.1 / AGR.2 / AGR.3	PA1.1、 PA2.1、 PA2.2；关键 供应商再看 PA3.1、 PA3.2	CL2	CL3
项目策划与控制	6.3.1 项目策划； 6.3.2 项目评估 与控制	PRO.1 / PRO.2	PA1.1、 PA2.1、 PA2.2	CL2	CL3
需求工程	6.4.2 利益相关 方需求；6.4.3 系 统/软件需求定义	ENG.1 + DEV.1	需求过程在 33022 中可 映射至 CL1-	CL2	CL3

			3		
架构定义	6.4.4 架构定义； 必要时结合 6.4.6 系统分析	ENG.3 + DEV.2	PA1.1、 PA2.1、 PA2.2；关键 系统建议达到 定义化	CL2	CL3
设计与实现	6.4.5 设计定义； 6.4.7 实现	DEV.3 / DEV.4	先确保过程结 果稳定，再谈 标准化模板	CL2	CL2
集成	6.4.8 集成	ENG.5 + DEV.5	关注 PA2.2 对构建物和环 境的一致控制	CL2	CL3
验证与确认	6.4.9 验证； 6.4.11 确认	SUP.4 / SUP.5 / SUP.6 + DEV.6	测试、评测、 审查证据要可 回溯	CL2	CL3
发布与过渡	6.4.10 过渡	ENG.7 / ENG.8	需要把回滚、 培训、上线证 据纳入 PA2.2	CL2	CL3
运行与维护	6.4.12 运行； 6.4.13 维护	ENG.9 / ENG.10	运营数据与缺 陷闭环决定是 否可持续达标	CL2	CL2-3
配置与变更管理	6.3.5 配置管理； 6.3.3 决策管理； 6.3.2 项目控制	PRO.5 + SUP.2 + AGR.3	关键是基线、 版本、审签与 追溯	CL2	CL3
质量保证与度量	6.2.5 质量管理； 6.3.7 度量； 6.3.8 质量保证	ORG.5 + PRO.7 + SUP.3	指标已采集不 等于达标，关 键在闭环与纠 偏	CL2	CL3
风险管理	6.3.4 风险管理	PRO.4	高风险过程建 议进入标准化 与部署化	CL2	CL3
安全与隐私治理	横切：6.2.5、 6.3.4、6.4.3、	无单独 legacy 过 程，分散嵌入	作为跨过程质 量要求评估；	CL2	CL3

	6.4.9、6.4.11、 6.4.12	PRO/ENG/SUP	重看 PA2.2 与 PA3.*		
信息与知识管理	6.3.6 信息管理； 6.2.6 知识管理	PRO.6 + ORG.4C	轻量团队至少 做到“能找得到、找得到最新版”	CL1-2	CL2

剪裁原则与具体方案

相关文件描述

- 12207 目录中有专门的 **Tailoring Process**；
- 24748-3 明确其不指定生命周期模型，适用于任何规模；
- 29110 则表明 25 人以下团队应优先围绕项目管理与软件实现组织过程。

上面这一组合对 6-10 人项目的启示非常明确：**先保证关键过程闭环，再决定是否把组织级过程升级为正式制度。**

下表给出关键剪裁结果。

过程/过程簇	采纳状态	剪裁理由	最低可接受活动	最低产物
业务/任务分析	轻量保留	小团队不适合独立长周期立项流程，但仍需明确目标和边界	用 1 页业务假设说明目标用户、价值、成功指标、约束	1 页项目章程/商业假设
供应商与接口管理	增强保留	LLM API 是关键外部依赖，缺失此过程会直接导致停服、超支或合	供应商评审、版本固定、配额告警、降级演练	供应商清单、版本矩阵、降级预案

		规失控		
项目策划与控制	完整保留	6-10 人团队 仍需范围、节奏、风险与资源控制	双周计划、WIP 限制、周会复盘	路线图、Sprint 计划、周报
需求工程	完整保留	LLM 项目需求波动高，若没有验收标准会把问题推给“模型不稳定”	故事拆解、验收标准、NFR 与数据约束	backlog、NFR 清单、验收标准
架构与设计	保留但 ADR 化	不需要厚重设计说明书，但必须保留关键架构决策	上线前完成关键 ADR 和数据流图评审	架构图、ADR、数据流图
实现	完整保留	标准工程活动，不可省	代码评审、单测、静态检查	PR 记录、源码、测试结果
集成/验证/确认	完整保留且自动化优先	小团队最容易在这里“偷跑”，但它决定发布风险	CI、契约测试、E2E、评测集回归、UAT	自动化测试报告、评测报告、UAT 结论
发布/过渡	完整保留	API 和提示模板都可能导致线上行为突变，必须可回滚	灰度、回滚、特性开关、发布审批	发布单、回滚预案、版本说明
运行/维护	完整保留	SaaS/小程序项目本质是长期运营系统	监控、告警、事故处理、缺陷修复	运行手册、事故单、复盘报告
配置/变更管理	增强保留	除源码外，还要管理提示模板、模型参数、检索配置	基线控制、变更审签、版本回溯	配置基线、变更记录、制品清单
质量保证/度	保留，审计轻	正式独立审计	周度质量例会、发	质量计划、指标仪表

量	量化	成本高，但审查点和指标不可缺失	布前质量门检查	盘、问题清单
风险管理	完整保留	供应商、隐私、成本和模型输出都需要显式风险管理	每周刷新风险登记册，发布前复核高风险项	风险登记册、应急清单
安全与隐私	增强保留	大模型项目的关键差异化过程	数据最小化、脱敏、日志治理、PIA/DPIA	权限矩阵、数据流图、脱敏规则
信息与知识管理	轻量保留	小团队依赖“口口相传”会在人员变动或事故时失效	固定文档目录、ADR 归档、复盘归档	文档索引、ADR 库、复盘库
组合管理、正式 HR 管理	项目内省略	单项目团队没有必要建立完整组织级制度	只保留关键技能与 backup owner 机制	技能矩阵、替补责任人表
处置/退役	延后实现,但不能缺席	上线初期通常不会立刻退役，但涉及数据保留和删除义务	在上线前形成最低退役清单	数据保留/删除策略、退役 checklist

四 实施建议与时间线

相关实施建议

建议采用如下**最小工具链结构**。

- 代码与变更统一进入 Git 平台；
- 需求和缺陷统一进入一个工作项系统；

- CI/CD 至少包括编译、单测、静态检查、镜像构建、制品归档、部署流水线；
- 运行期至少具备应用日志、接口追踪、指标与告警三类可观测能力；
- 面向 LLM 的专门能力至少包括评测集、提示模板版本化、输出审查和成本监控。

对于小团队，工具不宜过多，关键是**单点事实源**：需求、代码、构建、发布、指标与事故都能互相追溯。

建议的**最小文档集**如下：项目章程、产品 backlog、NFR 清单、3-5 个关键 ADR、API/数据流图、测试策略与评测集、发布清单、运维手册、事故复盘、风险登记册。

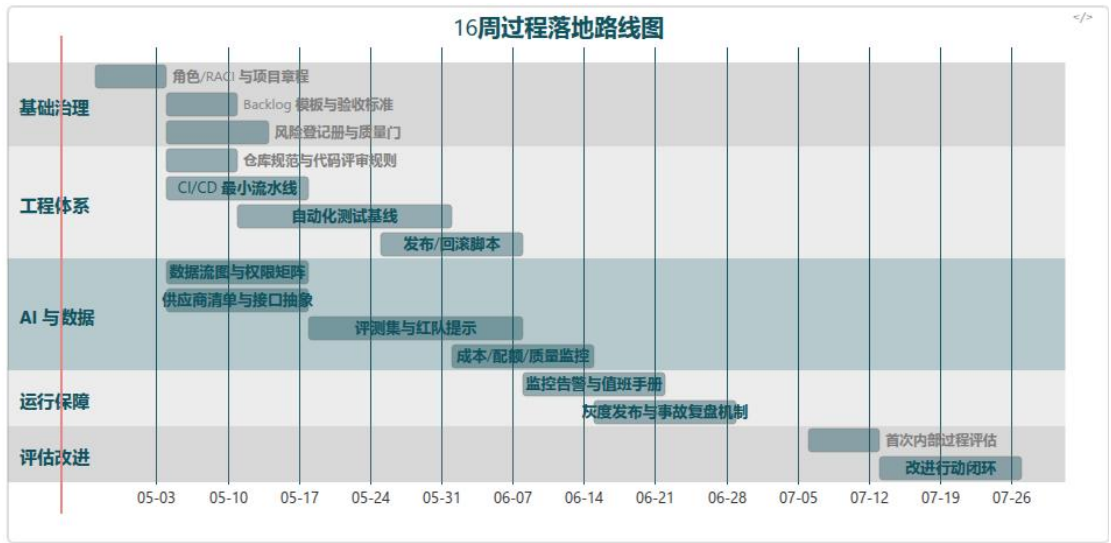
如果项目以大模型 API 为核心依赖，那么上线前至少应补齐四类自动化。

- 第一类是**基础自动化测试**，包括单元、契约、集成与冒烟。
- 第二类是**提示与评测自动化**，至少对 Top 20 关键业务场景保留 golden set。
- 第三类是**运维自动化**，包括配额/成本告警、故障降级与回滚。
- 第四类是**安全与隐私自动化**，包括密钥检查、依赖扫描、日志脱敏校验以及高风险动作需要人工审批。

项目参考时间线

下面给出一个小团队的 **16 周落地路线图**。场景 A 基本按图执行；场景 B 在“数据分级/DPIA”“供应商审查”“发布审批”和“首次内部评估”阶段应投

入更多时间。



五 质量评估与改进循环

相关文件描述：

- 12207 定义了“应有哪些过程”
- 15504/330xx 定义的就是“过程做到了什么水平”
- 33002 要求合格的评估结果必须是**客观、一致、可重复且能代表被评估过程**的
- 33004 规定 PRM、PAM 与成熟度模型之间的关系
- 020 给出能力测量框架；33022 把 12207 过程映射到 33020 的 1-3 级
- 15504-7 则把组织成熟度理解为**在给定范围内稳定实施一组过程能力画像的程度**

这意味着：对本项目做质量评估，最合适的方法不是追求抽象的“成熟度等级秀”，而是形成一个**过程画像（process profile）**，再用画像驱动改进。

对本项目，建议采用如下内部评估法。

- 1. 首先，**按过程簇而不是按整组织一次性评估。**
- 2. 其次，**证据来源固定为四类：**产物证据、工具证据、访谈证据、运行证据。
- 3. 再次，**评分不追求绝对精密，而追求重复性**
- 4. 最后，**改进闭环必须回到 backlog。**评估报告不能停留在“过程偏弱”的描述层，而要落为“谁在什么时间，把哪个过程属性提升到什么证据状态”。

下面给出建议的评估目标与业务/工程指标。

维度	指标	场景 A 目标	场景 B 目标	对应过程
过程能力	核心过程能力等级	大多数核心过程 CL2	关键过程 CL3，其余 CL2	全部
需求	Sprint 内需求变更率	≤ 15%	≤ 10%	需求、项目控制
交付	Lead time from merge to prod	≤ 3 天	≤ 7 天	实现、发布
稳定性	Change failure rate	≤ 15%	≤ 10%	集成、发布
可恢复性	MTTR	≤ 4 小时	≤ 2 小时	运维、维护
测试	关键路径自动化通过率	≥ 95%	≥ 98%	验证/确认
LLM 质量	Golden set 通过率	≥ 90%	≥ 95%	验证/确认
输出可靠性	幻觉/越权输出抽检不合格率	≤ 5%	≤ 2%	需求、验证、安全
供应商依赖	API 429/5xx 比例	≤ 1%	≤ 0.5%	供应商管理、运维
成本	月度 API 成本偏差	≤ 10%	≤ 5%	供应商管理、度量
隐私	PII 泄露事件	0	0	安全与隐私
可追溯性	高风险变更可追溯率	≥ 95%	100%	配置与变更管理